Access Control Policy

Organization: Apex Financial Services (Simulated)
Project: IAM & GRC Home Lab

1. Purpose

The purpose of this policy is to protect company information by making sure employees only have access to the systems and resources needed for their job responsibilities.

This policy follows Role-Based Access Control (RBAC) and the principle of least privilege to reduce unauthorized access and security risks.

2. Access Control Requirements

- Employees must receive permissions based on their assigned job roles.
- Access to sensitive information must be approved by an authorized manager.
- Employees must not receive administrative privileges unless required for their responsibilities.
- Access permissions must be updated when employees change roles or departments.

3. Account Management

- New employee accounts must be approved before access is granted.
- Accounts must be assigned permissions according to the approved RBAC matrix.
- Employee accounts must be disabled promptly after termination.
- Remaining permissions must be removed during the offboarding process.

4. Privileged Access

Administrative privileges must be restricted to authorized personnel.

Employees with privileged access should only receive the permissions necessary to perform their responsibilities.

Privileged accounts must be reviewed regularly to identify excessive or unnecessary permissions.

5. Access Reviews

The organization should conduct employee access reviews by verifying RBAC’s and catching any unauthorized access every 90 days.

6. Policy Compliance

Employees and administrators are expected to follow this policy.

Any identified access violations must be documented, evaluated based on risk, and addressed through the organization's remediation process.